

MeFirst Insurance - API Implementation Guide

1. Executive Summary

This API Implementation Guide defines MeFirst Insurance's approach to building a scalable, secure, and governed API ecosystem. It draws on industry frameworks and government-grade standards including DevSecOps, Zero Trust, and OpenAPI specifications. Our objective is to unify integration architecture, improve agility, and secure data flows for insurance operations.

2. API-First Strategy Overview

API-first emphasizes defining, documenting, and testing APIs early in the development lifecycle. This enables parallel workflows between front-end and back-end teams and reduces downstream integration friction.

According to Brightgrove's case study, implementing API-first led to:

- 185% improvement in response time
- 75% reduction in critical incidents
- 62.5% less maintenance time

MeFirst Insurance - API Implementation Guide

3. API Governance Model

Governance ensures compliance, lifecycle control, and service quality. Our model includes:

- Centralized API registry and specification validation
- Governance board approving design patterns, naming standards, and versioning
- Enforcement via GitOps and CI/CD policies

Governance Benefits (per DoD MVCR-1):

- Discoverable APIs reduce duplication
- High cohesion and loose coupling improve resilience

4. Technical Architecture

Our API architecture follows a 3-tiered pattern:

1. Experience APIs: exposed to external/mobile consumers
2. Process APIs: encapsulate business logic
3. System APIs: interact with legacy systems (e.g., mainframes)

Design adheres to OpenAPI 3.0, RESTful best practices, and ISO-8601 timestamp standards. APIs return well-documented HTTP responses with clear JSON schemas.

Example:

...

GET /claims/{id}

Response: {

"claimId": "12345",

"status": "Open",

"submittedDate": "2025-01-01T13:45:30Z"

}

...

5. Security & Compliance

Security integrates Zero Trust, encryption, and behavioral monitoring:

- OAuth2 and JWT for authorization
- Mutual TLS for transport security
- mTLS enforcement at API gateways

Runtime protection (per Microsoft security guide):

- CNAPP integrations for continuous monitoring
- Secrets scanning and rotation policies

Coverage:

- 100% encryption at rest and transit
- 80% fewer security incidents (Brightgrove)

6. DevSecOps Enablement

CI/CD pipelines embed security and testing:

- Static Analysis (SAST) via SonarQube
- Dynamic Tests (DAST) pre-deployment
- AI-driven fuzz testing for unknown vulnerabilities

Gatekeeper policies ensure only API-registered specs are deployed. Canary deployments and circuit breakers minimize risk during rollouts.

7. Monitoring and Observability

APIs are monitored using ELK stack and Azure Monitor. Key metrics include:

- Latency < 150ms (Brightgrove target)
- Uptime: 99.95%
- Real-time SLA dashboards for partners

Behavioral analytics help detect misuse and anomalous access patterns.

8. API Cataloging and Inventory

Using Azure API Center and SwaggerHub for:

- Central inventory of all APIs
- Auto-discovery of shadow APIs
- Version tracking and lifecycle transitions

Inventory accuracy is vital to prevent misuse, per OWASP API Top 10: API9 - Improper Inventory Management.

9. Use Cases

- **Claims Processing**: Intake, status updates, automated decisions
- **Underwriting**: Third-party data enrichment, risk scores via APIs
- **Partner Integrations**: Broker APIs for policy issuance
- **Customer Portals**: Policy management, self-service billing

10. Change Management and Training

Standard API onboarding kits include templates, OpenAPI samples, and Git repo structures. Dev teams complete training on secure API coding practices and governance compliance. All APIs undergo approval workflow prior to exposure.

11. Appendices

- Glossary of API Security Terms
- Example OpenAPI 3.0 Spec
- Architecture Diagram (System Process Experience API)
- OWASP API Security Top 10 2023
- DevSecOps Reference Architecture (DoD)